ACCESS-CONTROL-MODELS-LDAP

접근 통제 정책·보안모델·LDAP

연관 기출 · 127-2-6, 129-2-2, 133-4-3

한눈에 이해

로그인에 성공한 사람도 모든 자료를 볼 수 있는 것은 아니며, 업무·등급·속성에 따라 허용행위를 다시 결정합니다.

정의와 핵심 원리

접근 통제는 주체가 객체에 수행할 행위를 정책과 조건에 따라 허용·거부하는 기능입니다. 식별·인증 → 인가 결정 → 정책집행 → 감사의 절차로 설명하고 보안모델의 보호 목표를 구분합니다.

• DAC는 소유자의 재량, MAC는 중앙의 등급·레이블, RBAC는 역할과 권한, ABAC는 주체·객체·행위·환경 속성과 정책을 중심으로 결정합니다. 최소 권한·직무 분리·기본거부·정기회수와 정책 결정/집행 분리가 중요합니다.

• BLP는 기밀성을 위한no read up/no write down, Biba의 엄격모델은 무결성을 위한no read down/no write up으로설명합니다. Clark-Wilson은 인증된변환절차·무결성 검증·제약자료·직무 분리로 상업적무결성을 관리합니다. 목적·허용정보 흐름을 반대로쓰지않습니다.

• LDAP는 디렉터리접근 프로토콜이며 인증은 Bind로수행합니다. TLS 서버 검증 → 필요시서비스 계정검색 → 사용자DN확인 → 사용자 인증Bind → 권한속성조회·인가로 구성할 수 있습니다. 평문simpleBind·빈암호의 익명/비인증 의미·과다검색권한을 주의합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
BLP	기밀성;상향읽기·하향쓰기금지	비밀의낮은 등급유출방지
Biba	무결성;하향읽기·상향쓰기금지	오염된정보의 전파방지
Clark-Wilson	정당한 거래·직무 분리	승인변환절차와 감사

적용 예제

급여 수정 권한

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 인사입력자·승인자·감사자를분리

1. 입력자는초안수정만 하고 승인자는본인입력을 승인하지못합니다.
2. 정당한 변환API만 급여자료를 갱신하게합니다.
3. 무결성 검사와 감사 로그로 이상변경을 확인합니다.
4. 인증 성공과급여수정 인가를 독립평가합니다.

결과·해석: 역할·절차·감사로업무 불변조건을 유지합니다.

전제·주의: LDAP·ABAC는 공식 자료 확인;BLP/Biba/CW원논문전문은 미열람입니다.

답안 골격과 혼동 방지

정의·절차 → DAC/MAC/RBAC/ABAC → 3보안모델 → LDAP 흐름 → 정책집행·감사

- 인증과 인가를 동의어로쓰지않습니다.
- BLP와 Biba 읽기방향을혼동하지 않습니다.

내용을 가리고 회상

1. BLP가 낮은 등급쓰기를 막는이유는무엇입니까?
2. ABAC의환경속성예는무엇입니까?
3. LDAPBind성공이업무 인가를 보장합니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- RFC4513: LDAP Authentication Methods - R. Harrison / IETF; 2006-06; 확인 2026-11-05.
- NIST SP800-162: ABAC Definition and Considerations - NIST; 2014;2019갱신; 확인 2026-11-05.